AZURE DAY

AZURE DAY TORINO 2026

Sicurezza del codice - trovare e correggere le vulnerabilità con l'AI



Riccardo Cozzi



Andrea Nori

Microsoft

msc TECHNOLOGY

TORINO.NET

NET CODE

AZURE DAY

Platinum Sponsor

Microsoft

msc TECHNOLOGY

Technical Sponsor

TORINO NET

NET CODE

JET BRAINS

CHI SIAMO

ANDREA NORI

Microsoft - Cloud Solution Architect

https://www.linkedin.com/in/andreanori/





RICCARDO COZZI

Microsoft - Cloud Solution Architect

https://www.linkedin.com/in/riccardocozzi/

AGENDA

01 Il contesto

Sviluppo con l'AI e sicurezza del codice

02 MDASH: agenti e modelli

Funzionamento, capacità e perimetro

03 Prerequisiti e accesso

Defender, Foundry e autorizzazioni

04 Demo 1: Configurazione e setup

Configurazione di Foundry e Defender

05 Demo 2: Scansione e risultati

Portale, CLI, risultati e correzioni

06 Risorse e domande

Documentazione, discussione e feedback

Che cos’è Codename MDASH

Prima di tutto…cosa significa MDASH?

Multi-mo**D**el **A**gentic **S**canning **H**arness, sviluppato dal Microsoft Autonomous Code Security team

Cosa di intende per Harness

L'insieme di **orchestrazione**, **workflow** e **controlli** che **coordina** più modelli e agenti per raggiungere un risultato.

Nel caso di **MDASH**, il valore non risiede quindi in un singolo LLM perché il sistema orchestra **oltre 100 agenti specializzati**

Dove si trova?

All’interno del portale **Defender** nella sezione di **Exposure Management**

Attualmente in **Preview**



MDASH: Perché e quali differenze con i tool tradizionali?

	CONTROLLI TRADIZIONALI (SAST\DAST)	MICROSOFT MDASH
Analisi	Il codice o l'applicazione in funzione	Collegamenti e modifiche nell'applicazione
Segnalazione	Possibili problemi da verificare	Problemi con prove a supporto
Filtri	Il team distingue i rischi dai falsi allarmi	Gli agenti AI verificano le segnalazioni
Correzione	Il team prepara la soluzione	Propone e verifica una correzione
Aggiornamento	Richiede aggiornamenti ai controlli	Può integrare modelli AI più performanti

Obiettivo: meno tempo a verificare gli allarmi, più tempo per risolvere i problemi



Sviluppo con l’AI e sicurezza del codice

Velocità

L’AI accelera la scrittura del codice

Superficie

Codice e dipendenze ampliano ciò che va verificato

Segnalazioni

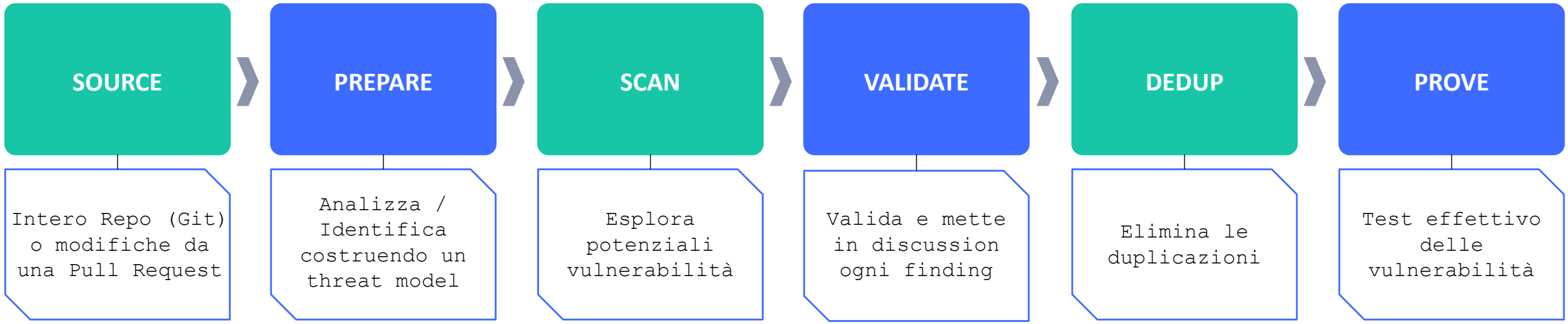
Il team sicurezza deve distinguere i rischi rilevanti

Correzione

Ogni vulnerabilità richiede un responsabile e un fix

La sicurezza deve accompagnare lo sviluppo, dalla verifica del codice alla correzione

Un sistema di oltre 100 agenti



Specializzazione

Ogni agente cerca una specifica classe di vulnerabilita.

Orchestrazione

Task, iterazioni e risultati sono coordinati dal sistema.

Evidenza

I finding vengono validati, consolidati e, dove possibile, provati.

Modelli diversi per compiti diversi (uso di MAI-Cyber-1-Flash)

Sicurezza del codice

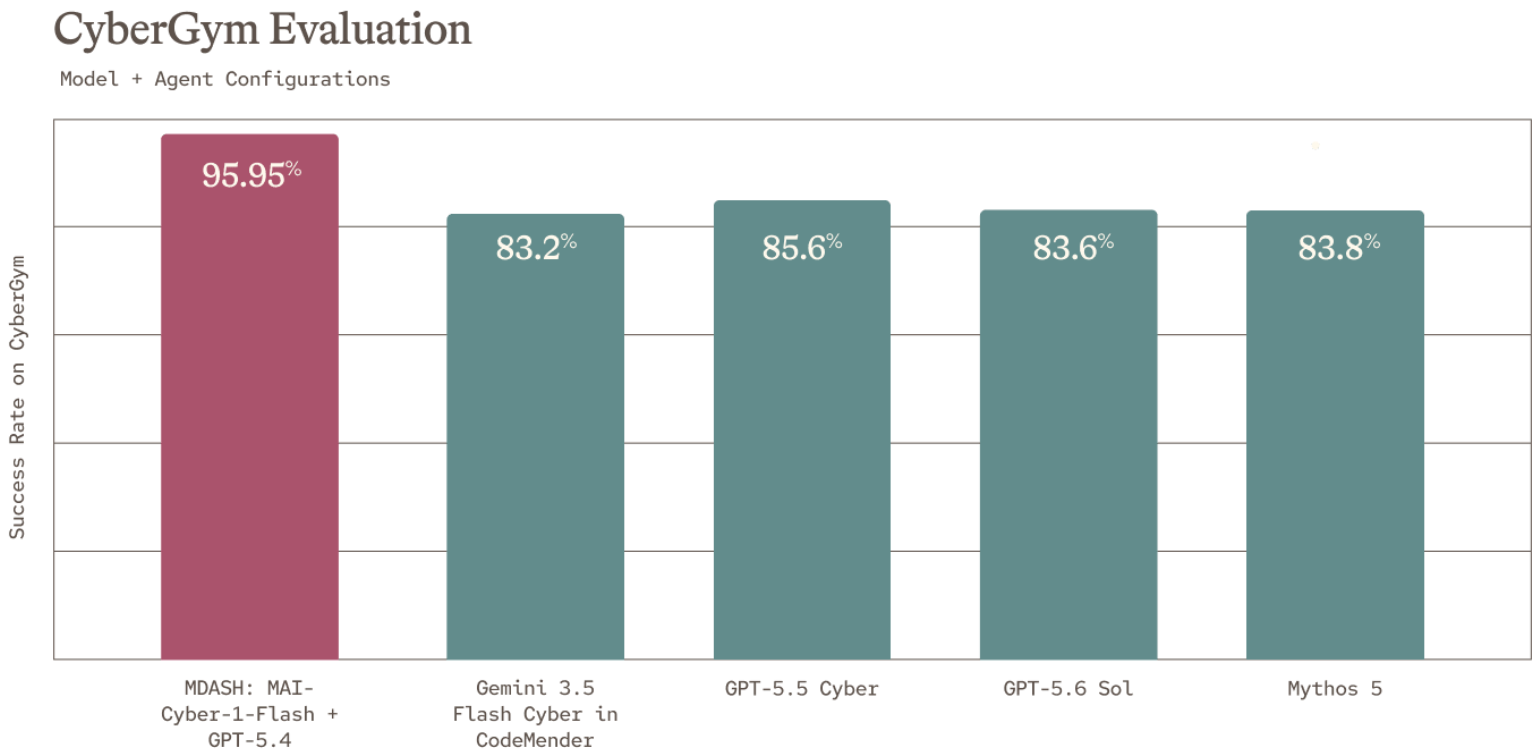
Cerca vulnerabilità complesse nel codice nel sistema multi-agente MDASH

Fino al 90% dei task

Gestisce la maggior parte dei task. GPT-5.4 copre i casi più complessi

Circa metà del costo

Performance migliorate riducendo il costo della scansione del 50%*



*Dati dichiarati da Microsoft. I risultati del benchmark e il risparmio non sono garanzie per ogni scansione

https://microsoft.ai/news/introducing-mai-cyber-1-flash-inside-mdash/



Funzionalità e perimetro

Analisi del codice	Repository GitHub e Azure DevOps tramite connettori, oppure codice locale tramite CLI
Priorità e validazione	Gravità, livello di confidenza e triage AI aiutano a valutare le segnalazioni
Correzioni suggerite	Il comando Defender fix genera e applica correzioni che devono essere revisionate e validate
Risultati centralizzati	Il Portale Defender raccoglie i risultati per il monitoraggio e il triage

https://learn.microsoft.com/en-us/security-exposure-management/ai-code-security-overview
https://learn.microsoft.com/en-us/security-exposure-management/mdash-initiative

Il ruolo di Defender e Microsoft Foundry



Repository

GitHub, Azure DevOps
o locali (solo via CLI)



Defender / MDASH

Orchestrazione dell'analisi



Microsoft Foundry

Vengono ospitati e serviti i
modelli necessari allo scanning



Risultati e fix

Triage e revisione del codice

Prerequisiti per utilizzare MDASH

- Accesso a Defender / Exposure Management
- Microsoft Entra ID: Global o Security Administrator
- Sottoscrizione Azure
- Risorsa Microsoft Foundry dedicata
- Permessi per distribuire modelli e collegare il codice
- Disponibilità della preview e licenze idonee da verificare

https://learn.microsoft.com/en-us/security-exposure-management/mdash-foundry-integration
https://learn.microsoft.com/en-us/security-exposure-management/ai-code-security-onboarding

Accesso e autorizzazioni per MDASH

Permessi per le scansioni

Defender RBAC separa scansione, invio e gestione dei risultati. Per la CLI, i permessi dipendono dall'autenticazione

Ruoli per l'attivazione

In Entra ID: Global Administrator o Security Administrator, con facoltà di accettare i termini del servizio

Risorsa Foundry dedicata

Servono una risorsa esclusiva per MDASH, i modelli richiesti e accesso di rete consentito al servizio.
(la scelta del data-boundary è confinata nella region della risorsa Foundry)

Autenticazione della CLI

La CLI supporta accesso interattivo per gli utenti oppure autenticazione tramite app per pipeline e automazioni



Riassunto dei requisiti tecnici

Accessi e Identità

- Accesso a Entra per creare enterprise app multi-tenant e fornire il consenso amministrativo per un flusso delegato (Global Admin)
- Ruoli Defender URBAC assegnati agli utenti (Security Admin)
- Permessi separati per eseguire scansioni, caricare risultati e visualizzare i risultati ottenuti
- Account GitHub con accesso in lettura (scrittura per le eventuali correzioni) ai repository

Calcolo AI — Microsoft Foundry

- Sottoscrizione Microsoft Azure con diritti amministrativi per creare una nuova risorsa Foundry
- Capacità di calcolo disponibile per Microsoft Foundry nella region selezionata
- Distribuzione dei 3 modelli richiesti (forniti durante l'onboarding)
- Content filtering modificato per l'accessibilità dei modelli
- Region e data boundary sono a scelta del cliente
- Il cliente paga l'elaborazione dei modelli all' interno della region selezionata

Perimetro di Scansione

- È sufficiente l'accesso in sola lettura ai repository
- Scansione fino a ~5–10 milioni di righe di codice, sia per repository presenti on-prem che in cloud
- Oltre 13 linguaggi:

C, C++, C#, Rust, Go, Python, JS/TS, Java, Ruby, Kotlin, PHP, Swift, Zig

- Defender CLI disponibile su sistemi Windows, Mac e Linux

Auto-fix (opzionale)

- Licenza GitHub Copilot necessaria per generare e applicare le correzioni

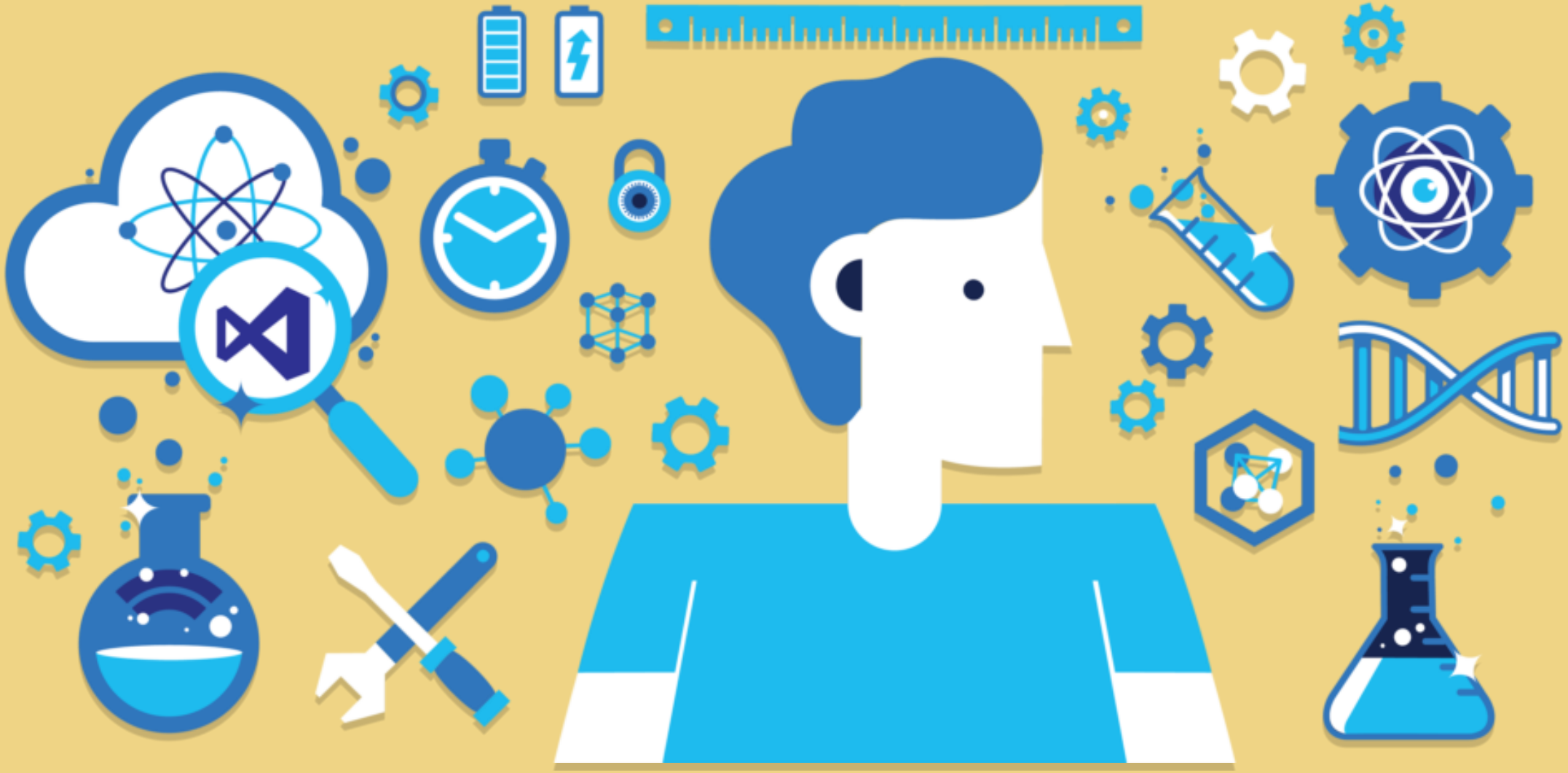
Preview

- Coperta da NDA — contenuti preliminari e confidenziali
- Accettazione degli eventuali accordi di preview aggiuntivi nel portale Defender
- Adesione tramite il flusso di onboarding integrato in Defender
- Funzionalità e condizioni soggette a modifiche

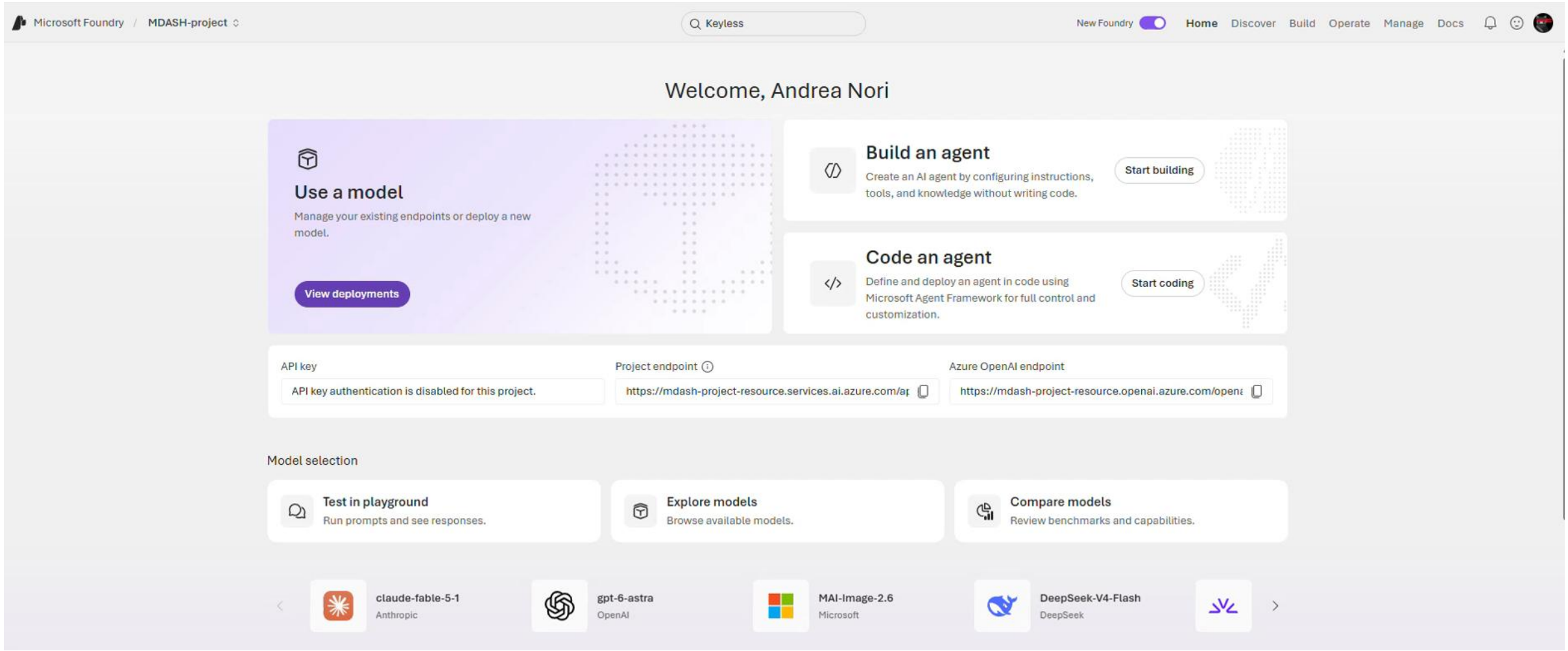
Codename MDASH Overview - Microsoft Security Exposure Management | Microsoft Learn

AZURE DAY

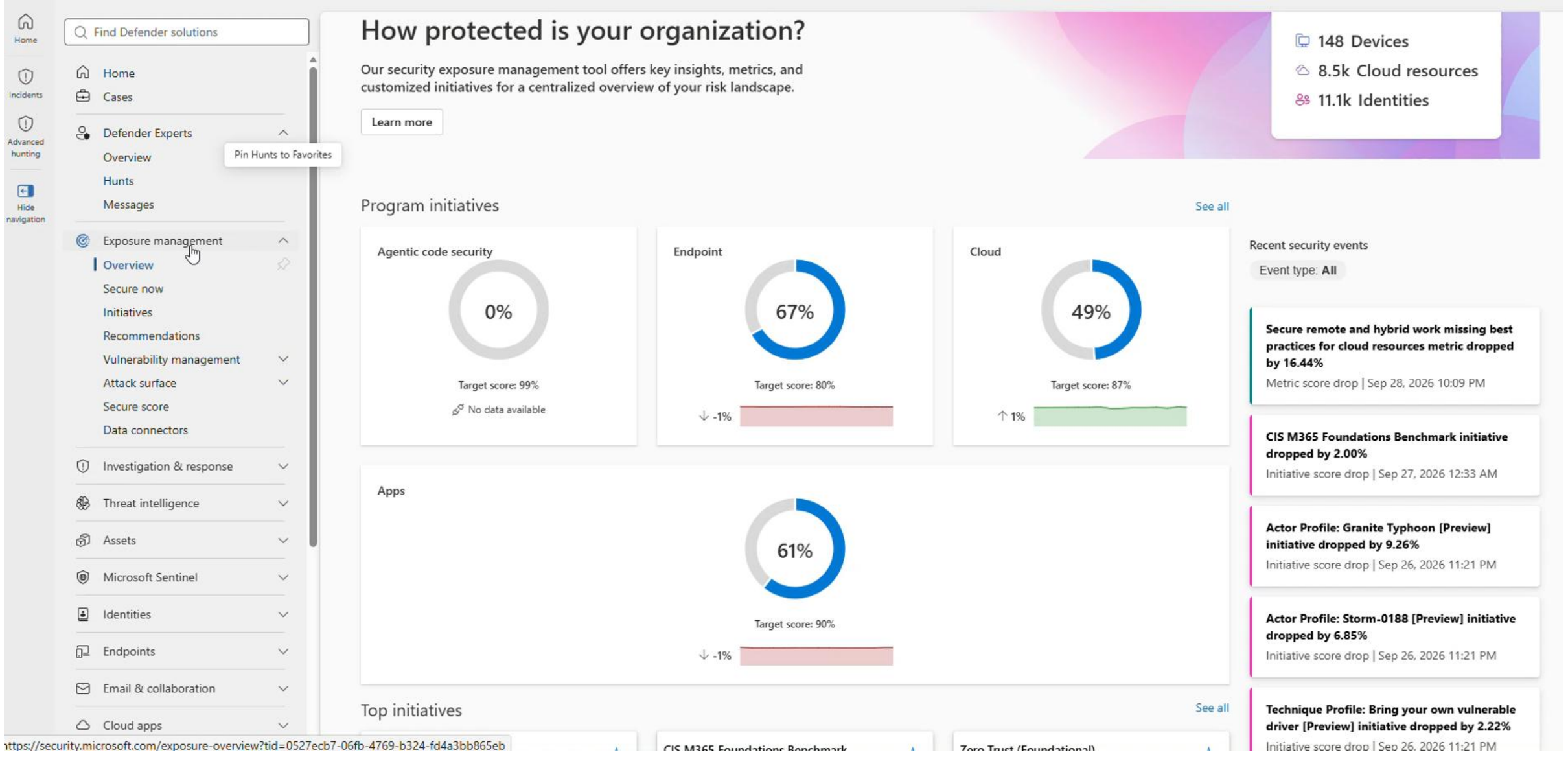
Demo



DEMO 1: Configurazione di Foundry



DEMO 1: Configurazione nel portale Defender



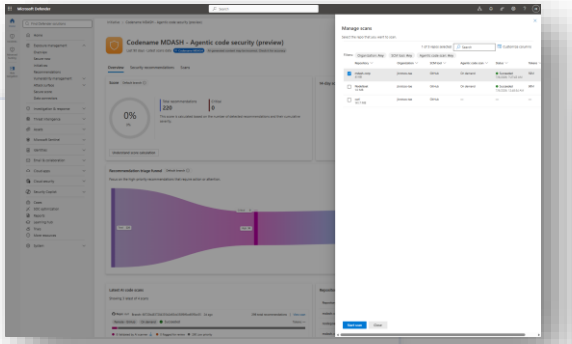


Percorso verso la prima scansione

1	**Verifica di accesso e requisiti**	Disponibilità nel tenant, ruoli, Azure e Foundry
2	**Definizione del pilota**	Repository, responsabili e criteri di successo
3	**Configurazione**	Termini, Foundry, connettori e autorizzazioni
4	**Analisi e revisione**	Triage, fix proposto, test e valutazione dei risultati

Due modalità di scansione

Dal portale Defender



- Configura il connettore GitHub o Azure DevOps
- Seleziona i repository
- Avvia la scansione e consulta i risultati

Dalla Defender CLI



- Configura l’autenticazione
- Avvia l’analisi del codice locale
- Usa defender fix per le correzioni

DEMO 2: Defender CLI, Recommendations e scan

```
PS C:\defendercli> az login --tenant [redacted]/Defender.InteractiveLogin --allow-no-subscriptions
Select the account you want to log in with. For more information on login with Azure CLI, see https://go.microsoft.com/fwlink/?linkid=2271136

Retrieving subscriptions for the selection...

[Tenant and subscription selection]

No     Subscription name                Subscription ID                      Tenant
-----  -------------------------------  -----------------------------------  -----------------------------------
[1]    Cloud Security                   [redacted]                           [redacted]
[2]    External ID                      [redacted]                           [redacted]
[3]    Identity                         [redacted]                           [redacted]
[4] *  Microsoft Azure Sponsorship 2    [redacted]                           [redacted]
[5]    Microsoft Azure Sponsorship 2    [redacted]                           [redacted]
[6]    ModernWork                       [redacted]                           [redacted]
[7]    Network Security                 [redacted]                           [redacted]
[8]    Purview                          [redacted]                           [redacted]
[9]    Woodgrove - GTP Demos (External/S...  [redacted]                      [redacted]
[10]   Woodgrove - SANDBOXv2           [redacted]                           [redacted]

The default is marked with an *; the default tenant is [redacted] and subscription is 'Microsoft Azure Sponsorship 2' ([redacted]).

Select a subscription and tenant (Type a number or Enter for no changes):

Tenant: 536279f6-15cc-45f2-be2d-61e352b51eef
Subscription: Microsoft Azure Sponsorship 2 ([redacted])

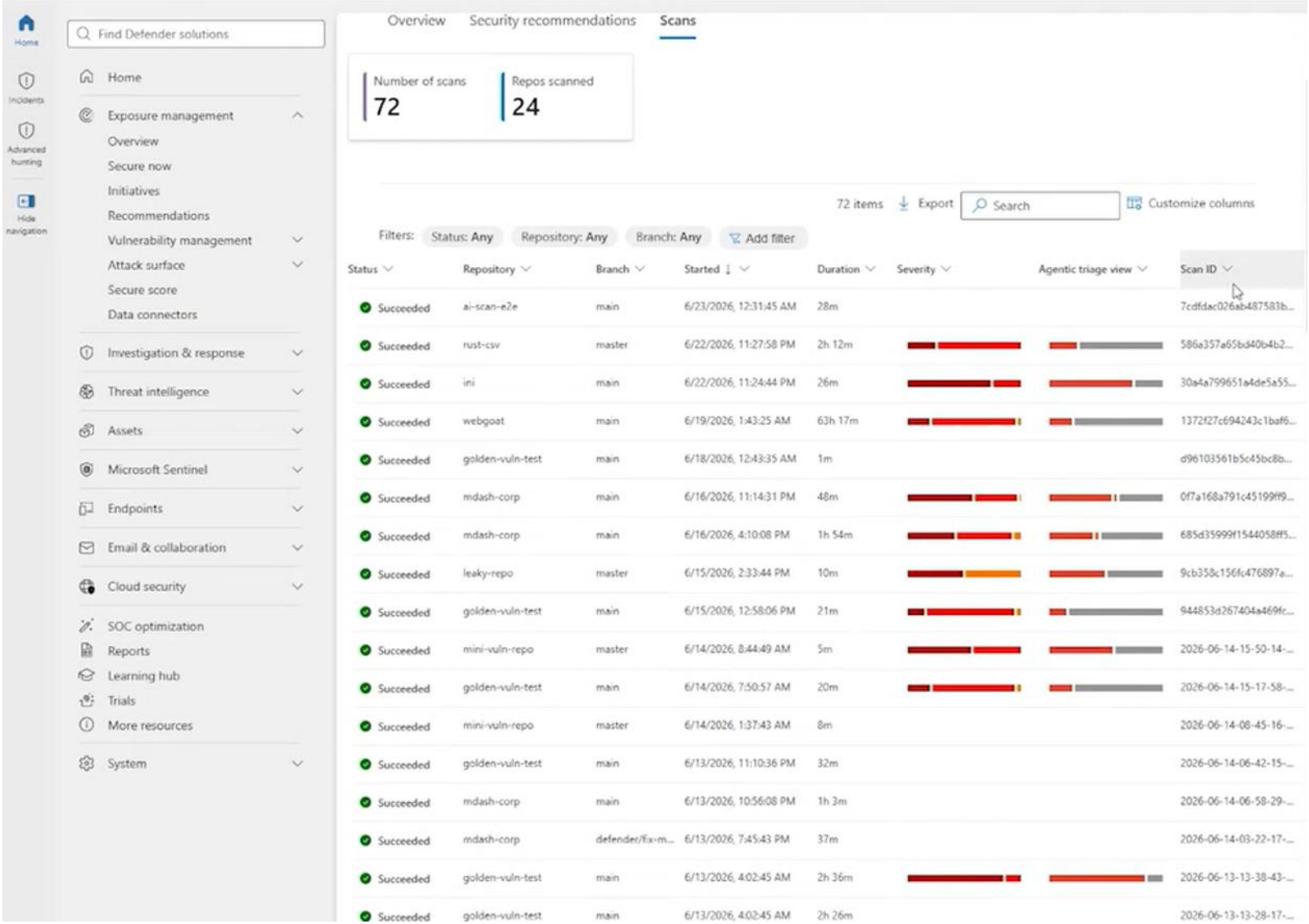
[Announcements]
With the new Azure CLI login experience, you can select the subscription you want to use more easily. Learn more about it and its configuration at https://go.microsoft.com/fwlink/?linkid=2271236

If you encounter any problem, please open an issue at https://aka.ms/azclibug

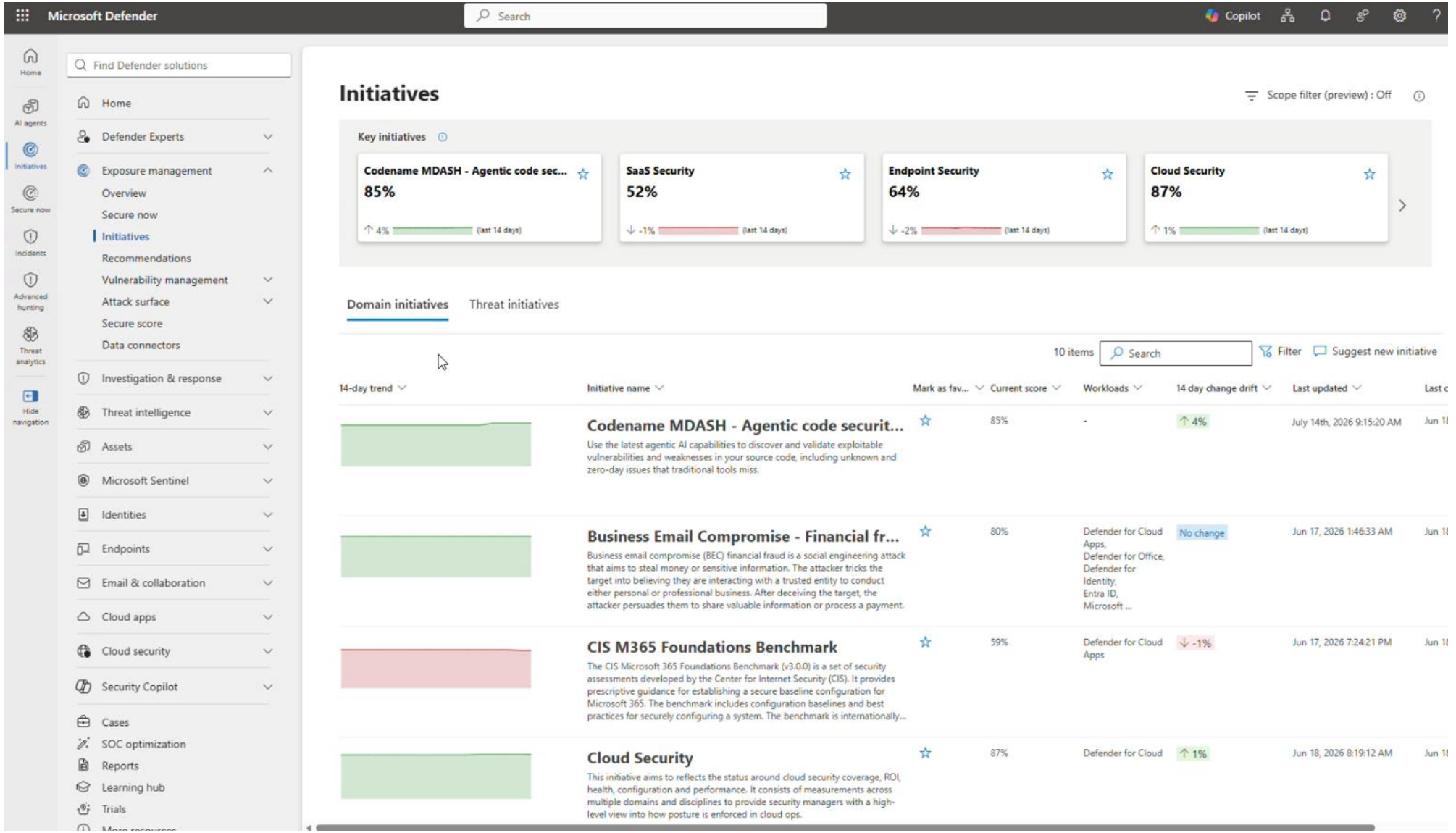
[Warning] The login output has been updated. Please be aware that it no longer displays the full list of available subscriptions by default.

PS C:\defendercli>
```

DEMO 2: Risultati e triage



DEMO 2: Recommendations e remediation steps





Documentazione e fonti



Codename MDASH: overview

Funzionalità, pipeline e supporto dei linguaggi

Microsoft Learn: overview



Onboarding e configurazione

Prerequisiti, accessi e collegamento a Foundry

Microsoft Learn: onboarding



MAI-Cyber-1-Flash in MDASH

Configurazione dei modelli e risultati dichiarati

Microsoft AI: annuncio



Domande e discussione



AZURE DAY

Valuta questa sessione



Sicurezza del codice con l’AI

Grazie per il tuo feedback

https://vote.dotnetdev.it/vote/l44tzzta/1299551